

第9章

数字证书与公钥基础设施

9.1 PKI 的基本概念

9.1.1 PKI 的定义

PKI 是一种遵循标准的利用公钥理论和技术建立的提供安全服务的基础设施。所谓基础设施,就是在某个大型环境下普遍适用的基础和准则,只要遵循相应的准则,不同实体即可方便地使用基础设施所提供的服务。例如,通信基础设施(网络)允许不同机器之间为不同的目的交换数据;电力供应基础设施可以让各种电力设备获得运行所需要的电压和电流。

公钥基础设施的目的是从技术上解决网上身份认证、电子信息的完整性和不可抵赖性等安全问题,为网络应用(如浏览器、电子邮件、电子交易)提供可靠的安全服务。PKI 是遵循标准的密钥管理平台,能为所有网络应用透明地提供采用加密和数字签名等密码服务所需的密钥和证书管理。

PKI 最主要的任务是确立可信任的数字身份,而这些身份可被用来和密码机制相结合,提供认证、授权或数字签名验证等服务,而使用该类服务的用户可在一定程度确信自己的行为未被误导。这一可信的数字身份通过数字证书(也称公钥证书)来实现。数字证书(如 X.509 证书,可参见 9.2 节)是用户身份与其所持公钥的结合。

在实用中,PKI 体系在安全、易用、灵活、经济的同时,必须充分考虑互操作性和可扩展性。PKI 体系所包含的证书机构(Certificate Authority, CA)、注册机构(Registration Authority, RA)、策略管理、密钥(Key)与证书(Certificate)管理、密钥备份与恢复、撤销系统等功能模块需有机结合;此外,安全应用程序的开发者不必再关心复杂的数学模型和运算,只需直接按照标准使用 API 接口即可实现相应的安全服务。

9.1.2 PKI 的组成

1. 证书机构

PKI 系统的关键是实现密钥管理。目前较好的密钥管理解决方案是采取证书机制。数字证书即是公开密钥体制的一种密钥管理媒介。数字证书是一种具有权威性的电子文档,其作用是证明证书中所列用户身份与证书中所列公开密钥合法且一致。要证明其合法性,就需要有可信任主体对用户证书进行公证,证明主体的身份及其与公钥的匹配关系,证书机构即是这样的可信任机构。

CA 也称数字证书认证中心(认证中心),作为具有权威性、公正性的第三方可信任

机构，是 PKI 体系的核心构件。CA 负责发放和管理数字证书，其作用类似于现实生活中的证件颁发部门，如护照办理机构。

CA 提供网络身份认证服务、负责证书签发及签发后证书生命周期中的所有方面的管理，包括跟踪证书状态且在证书需要撤销（吊销）时发布证书撤销通知。CA 还需维护证书档案和证书相关的审计，以保障后续验证需求。CA 系统的功能如图 9-1 所示，详细的证书与密钥管理请参见 9.2 节。

2. 注册机构

注册机构（RA，也称注册中心）是数字证书注册审批机构，是认证中心的延伸，与 CA 在逻辑上是一个整体，执行不同的功能。RA 按照特定政策与管理规范对用户的资格进行审查，并执行“是否同意给该申请者发放证书、撤销证书”等操作，承担因审核错误而引起的一切后果。如果审核通过，即可实时或批量地向 CA 提出申请，要求为用户签发证书。RA 并不发出主体的可信声明（证明），只有证书机构有权颁发证书和撤销证书。RA 将与具体应用的业务流程相联系，是最终客户和 CA 交互的纽带，是整个 CA 中心得以运作的不可缺少的部分。

RA 负责对证书申请进行资格审查，其主要功能如下。

- (1) 填写用户注册信息：替用户填写有关用户证书申请信息。
- (2) 提交用户注册信息：核对用户申请信息，决定是否提交审核。
- (3) 审核：对用户的申请进行审核，决定“批准”还是“拒绝”用户的证书申请。
- (4) 发送生成证书申请：向 CA 提交生成证书请求。
- (5) 发放证书：将用户证书和私钥发放给用户。
- (6) 登记黑名单：对过期的证书和撤销的证书及时登记，并向 CA 发送。
- (7) 证书撤销列表管理：确保 CRL 的及时性，并对 CRL 进行管理。
- (8) 日志审计：维护 RA 的操作日志。
- (9) 自身安全保证：保障服务器自身密钥数据库信息、相关配置文件安全。

RA 系统的功能如图 9-2 所示。

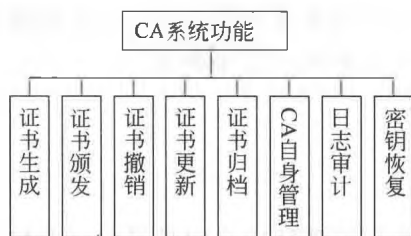


图 9-1 CA 系统的功能

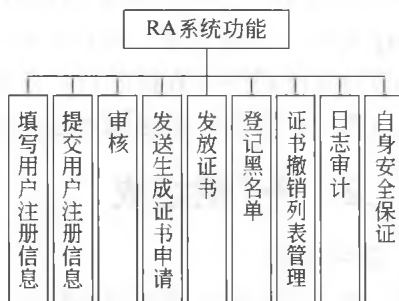


图 9-2 RA 系统的功能

3. 证书发布库

证书发布库（简称证书库）集中存放 CA 颁发证书和证书撤销列表（Certificate Revocation List, CRL）。证书库是网上可供公众进行开放式查询的公共信息库。公众查

询的目的通常有两个：①得到与之通信的实体的公钥；②验证通信对方的证书是否在“黑名单”中。

在轻量级目录访问协议（Lightweight Directory Access Protocol, LDAP）尚未出现以前，通常由各应用程序使用各自特定的数据库来存储证书及 CRL，并使用各自特定的协议实现访问。这种方案存在很大的局限性，因为数据库和访问协议的不兼容性，使得人们无法使用其他应用程序实现对证书及 CRL 的访问。LDAP 作为一种标准的开发协议，使以上问题得到了解决。此外，证书库还应该支持分布式存放，即将与本组织有关的证书和证书撤销列表存放在本地，以提高查询效率。在 PKI 所支持用户数量较大的情形下，PKI 信息的及时性和强有力的分布机制将非常关键。LDAP 目录服务支持分布式存放，是大规模 PKI 系统成功实施的关键，也是创建高效的认证机构的关键技术。

4. 密钥备份与恢复

针对用户密钥丢失的情形，PKI 提供密钥备份与恢复机制。密钥备份和恢复只能针对加/解密密钥，而无法对签名密钥进行备份。数字签名是用于支持不可否认服务的，有时间性要求，因此不能备份/恢复签名密钥。

密钥备份在用户申请证书阶段进行，如果注册声明公/私钥对是用于数据加密的，则 CA 即可对该用户的私钥进行备份。当用户丢失密钥后，可通过可信任的密钥恢复中心或 CA 完成密钥恢复。

5. 证书撤销

证书由于某些原因需要作废时，如用户身份姓名的改变、私钥被窃或泄漏、用户与所属企业关系变更等，PKI 需要使用一种方法警告其他用户不要再使用该用户的公钥证书，这种警告机制被称为证书撤销。

证书撤销的主要实现方法有以下两种。

（1）利用周期性发布机制，如证书撤销列表（Certificate Revocation List, CRL）。证书撤销消息的更新和发布频率非常重要，两次证书撤销信息发布之间的间隔称为撤销延迟。在特定 PKI 系统中，撤销延迟必须遵循相应的策略要求。

（2）在线查询机制，如在线证书状态协议（Online Certificate Status Protocol, OCSP）。在 9.2 节将详细介绍证书撤销方法。

6. PKI 应用接口

PK 研究的初衷就是令用户能方便地使用加密、数字签名等安全服务，因此一个完善的 PKI 必须提供良好的应用接口系统，使得各种应用能够以安全、一致、可信的方式与 PKI 交互，确保安全网络环境的完整性和易用性。PKI 应用接口系统应该是跨平台的。

9.1.3 PKI 的应用

PKI 的应用非常广泛，如安全浏览器、安全电子邮件、电子数据交换、Internet 上的信用卡交易及 VPN 等。PKI 作为安全基础设施，它能够提供的主要服务如下。

1. 认证服务

认证服务即身份识别与认证，就是确认实体即为自己所声明的实体，鉴别身份的

真伪。

以甲乙双方的认证为例：甲首先要验证乙的证书的真伪，乙在网上将证书传送给甲，甲用 CA 的公钥解开证书上 CA 的数字签名，若签名通过验证，则证明乙持有的证书是真的；接着甲还要验证乙身份的真伪，乙可将自己的口令用其私钥进行数字签名传送给甲，甲已从乙的证书库中查得了乙的公钥，甲即可用乙的公钥来验证乙的数字签名。若该签名通过验证，乙在网上的身份就确凿无疑了。

2. 数据完整性服务

数据完整性服务就是确认数据没有被修改过。实现数据完整性服务的主要方法是数字签名，它既可以提供实体验证，又可以保障被签名数据的完整性，这由杂凑算法和签名算法提供保证。杂凑算法的特点是输入数据的任何变化都会引起输出数据不可预测的极大变化，而签名是用自己的私钥将该杂凑值进行加密，然后与数据一同传送给接收方。如果敏感数据在传输和处理过程中被篡改，接收方就不会收到完整的数字签名，验证就会失败。反之，若签名通过了验证，就证明接收方收到的是未经修改的完整数据。

3. 数据保密性服务

PKI 的保密性服务采用了“数字信封”机制，即发送方先产生一个对称密钥，并用该对称密钥加密数据。同时，发送方还用接收方的公钥加密对称密钥，就像把它装入一个“数字信封”，然后把被加密的对称密钥（“数字信封”）和被加密的敏感数据一起传送给接收方。接收方用自己的私钥拆开“数字信封”，并得到对称密钥，再用对称密钥解开被加密的敏感数据。

4. 不可否认服务

不可否认服务是指从技术上保证实体对其行为的认可。在这中间，人们更关注的是数据来源的不可否认性、接收的不可否认性及接收后的不可否认性，此外还有传输的不可否认性、创建的不可否认性和同意的不可否认性。

5. 公证服务

PKI 中的公证服务与一般社会提供的公证人服务有所不同，PKI 中支持的公证服务是指“数据认证”，也就是说，公证人要证明的是数据的有效性和正确性，这种公证取决于数据验证的方式。例如，在 PKI 中被验证的数据是基于杂凑值的数字签名、公钥在数学上的正确性和签名私钥的合法性。

PKI 提供的上述安全服务能很好地满足电子商务、电子政务、网上银行、网上证券等行业的安全需求，是确保这些活动能够顺利进行的安全措施。

9.2

数字证书

PKI 与非对称加密密切相关，涉及消息摘要、数字签名与加密等服务。数字证书技术则是支持以上服务的 PKI 关键技术之一。

数字证书可理解为相当于护照、驾驶执照之类用以证明实体身份的证件。例如，护照可以证明实体的姓名、国籍、出生日期和地点、照片与签名等方面信息。类似地，数字证书也可以证明网络实体在特定安全应用的相关信息。

数字证书就是一个用户的身份与其所持有的公钥的结合，在结合之前由一个可信任的权威机构 CA 来证实用户的身份，然后由该机构对该用户身份及对应公钥相结合的证书进行数字签名，以证明其证书的有效性。

9.2.1 数字证书的概念

数字证书实际上是一个计算机文件，该数字证书将建立用户身份与其所持公钥的关联。其主要包含的信息有主体名 (Subject Name)，数字证书中任何用户名均称为主体名 (即使数字证书可能颁发给个人或组织)；序号 (Serial Number)；有效期；签发者名 (Issuer Name)。数字证书的示例如图 9-3 所示。

由表 9-1 可见，常规护照与数字证书项目非常相似。同一签发者签发的护照不会有重号，同样，同一签发者签发的数字证书的序号也不会重复。签发数字证书的机构通常为一些著名组织，世界上最著名的证书机构为 VeriSign 与 Entrust。在国内，许多政府机构和企业也建立了自己的 CA 中心。例如，我国的 12 家银行联合组建了 CFCA。证书机构有权向个人和组织签发数字证书，使其可在非对称加密应用中使用这些证书。

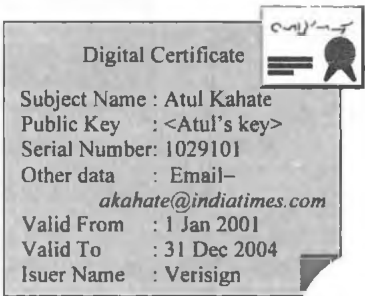


图 9-3 数字证书的示例

表 9-1 常规护照与数字证书项目比对

常规护照项目	数字证书项目
姓名 (Full Name)	主体名 (Subject Name)
护照号 (Passport Number)	序号 (Serial Number)
起始日期 (Valid From)	起始日期 (Valid From)
终止日期 (Valid To)	终止日期 (Valid To)
签发者 (Issued By)	签发者名 (Issuer Name)
照片与签名 (Photograph And Signature)	公钥 (Public Key)

9.2.2 数字证书的结构

数字证书的结构在 Satyam 标准中定义。国际电信联盟 (ITU) 于 1988 年推出这个标准，当时放在 X.500 标准中。后来，X.509 标准于 1993 年和 1995 年做了两次修订。这个标准的最新版本是 X.509 v3。1999 年，Internet 工程任务小组 (IETF) 发表了 X.509 标准的草案 RFC 2459。

图 9-4 是 X.509 v3 数字证书的结构，显示出 X.509 标准指定的数字证书字段，还指定了字段对应的标准版本。可以看出，X.509 标准第 1 版共有 7 个基本字段，第 2 版增加了两个字段，第 3 版增加了 1 个字段。增加的字段分别被称为第 2 版和第 3 版的扩展

或扩展属性。这些版本的末尾还有 1 个共同字段。表 9-2（a）、表 9-2（b）、表 9-2（c）列出了这 3 个版本中的字段描述。

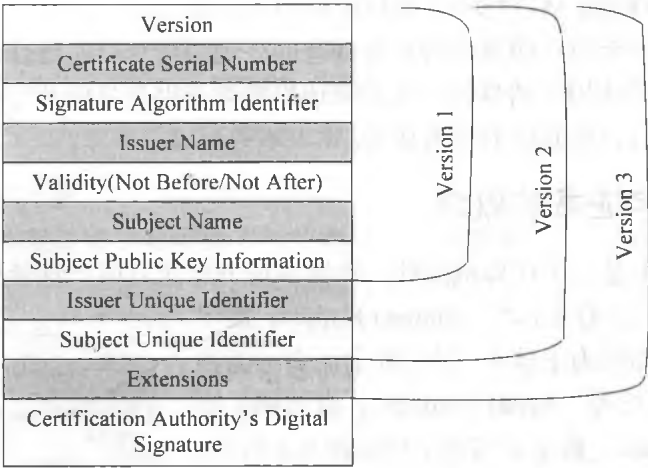


图 9-4 X.509 v3 数字证书的结构

表 9-2 X.509 数字证书字段描述

(a) 第 1 版	
字 段	描 述
版本（Version）	标识本数字证书使用的 X.509 协议版本，目前可取 1/2/3
证书序号 （Certificate Serial Number）	包含 CA 产生的唯一整数值
签名算法标识符 （Signature Algorithm Identifier）	标识 CA 签名数字证书时使用的算法
签名者（Issuer Name）	标识生成、签名数字证书的 CA 的可区分名（DN）
有效期（之前/之后） （Validity（Not Before/Not After））	包含两个日期时间值（之前/之后），指定数字证书有效的时间范围。通常指定日期、时间，精确到秒或毫秒
主体名（Subject Name）	标识数字证书所指实体（即用户或组织）的可区分名（DN）除非 v3 扩展中定义了替换名，否则该字段必须有值
主体公钥信息 （Subject Public Key Information）	包含主体的公钥与密钥相关的算法，该字段不能为空
(b) 第 2 版	
字 段	描 述
签发者唯一标识符 （Issuer Unique Identifier）	在两个或多个 CA 使用相同签发者名时标识 CA
主体唯一标识符 （Subject Unique Identifier）	在两个或多个主体使用相同签发者名时标识 CA

续表

(c) 第 3 版	
字 段	描 述
机构密钥标识符 (Authority Key Identifier)	单个证书机构可能有多个公钥/私钥对，本字段定义该证书的签名使用哪个密钥对（用相应密钥验证）
主体密钥标识符 (Subject Key Identifier)	主体可能有多个公钥/私钥对，本字段定义该证书的签名使用哪个密钥对（用相应密钥验证）
密钥用法 (Key Usage)	定义该证书的公钥操作范围。例如，可以指定该公钥可用于所有密码学操作或只能用于加密，或者只能用于 Diffie-Hellman 密钥交换，或者只能用于数字签名，等等
扩展密钥用法 (Extended Key Usage)	可补充或替代密钥用法字段，指定该证书可采用哪些协议，这些协议包括 TLS（传输层安全协议）、客户端认证、服务器认证、时间戳等
私钥使用期 (Private Key Usage Period)	可对该证书对应的公钥/私钥对定义不同的使用期限。若本字段为空，则该证书对应的公钥/私钥对定义相同的使用期限
证书策略 (Certificate Policies)	定义证书机构对某证书指定的策略和可选限定信息
证书映射 (Policy Mappings)	在某证书的主体也是证书机构时使用，即，一个证书机构向另一证书机构签发证书，指定认证的证书机构要遵循哪些策略
主体替换名 (Subject Alternative Name)	对证书的主体定义一个或多个替换名，但如果主证书格式中的主体名字段为空，则该字段不能为空
签发者替换名 (Issuer Alternative Name)	可选择定义证书签发者的一个或多个替换名
主体目录属性 (Subject Directory Attributes)	可提供主体的其他信息，如主体电话/传真、电子邮件地址等
基本限制 (Basic Constraints)	表示该证书主体可否作为证书机构。本字段还指定主体可否让其他主体作为证书机构。例如，若证书机构 X 向证书机构 Y 签发该证书，则 X 不仅能指定 Y 可否作为证书机构向其他主体签发证书，还可指定 Y 可否指定别的主体作为证书机构
名称限制 (Name Constraints)	指定名字空间
策略限制 (Policy Constraints)	只用于 CA 证书

9.2.3 数字证书的生成

本节介绍数字证书生成的典型过程。数字证书生成与管理主要涉及的参与方有最终用户、注册机构、证书机构。和数字证书信息紧密相关的机构有最终用户（主体）和证书机构（签发者）。证书机构的任务繁多，如签发新证书、维护旧证书、撤销因故无效证书等，因此一部分证书生成与管理任务由第三方——注册机构（RA）完成。从最终用户角度看，证书机构与注册机构差别不大。技术上，注册机构是用户与证书机构之间的中间实体，如图 9-5 所示。

注册机构提供的服务有：①接收与验证最终用户的注册信息；②为最终用户生成密钥；③接收与授权密钥备份与恢复请求；④接收与授权证书撤销请求。

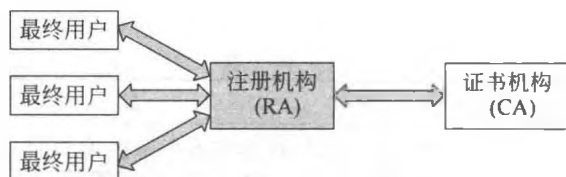


图 9-5 最终用户与 RA 和 CA 的关系

注意：注册机构主要帮助证书机构与最终用户间交互，注册机构不能签发数字证书，证书只能由证书机构签发。

数字证书的生成步骤如图 9-6 所示，下面对各步进行详细介绍。

第 1 步：密钥生成。生成密钥可采用的方式有如下两种。

(1) 主体（用户/组织）可采用特定软件生成公钥/私钥对，该软件通常是 Web 浏览器或 Web 服务器的一部分，也可以使用特殊软件程序。主体必须秘密保存私钥，并将公钥、身份证明与其他信息发送给注册机构，如图 9-7 所示。

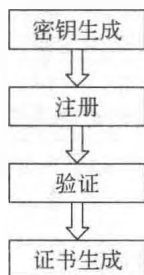


图 9-6 数字证书的生成步骤

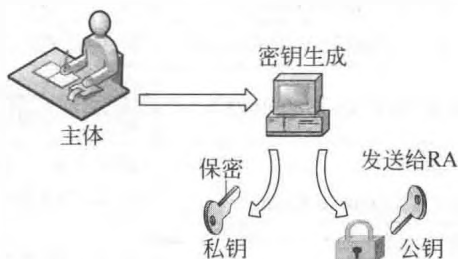


图 9-7 主体生成密钥对

(2) 当用户不知道密钥对生成技术或要求注册机构集中生成和发布所有密钥，以便于执行安全策略和密钥管理时，也可由注册机构为主体（用户）生成密钥对。该方法的缺陷是注册机构知道用户私钥，且在向主体发送途中也可能泄漏。注册机构为主体生成密钥对示意图如图 9-8 所示。

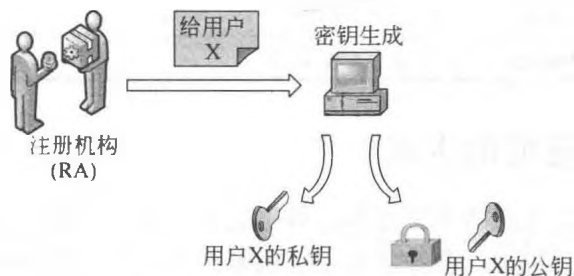


图 9-8 注册机构主体生成密钥对示意图

第 2 步：注册。该步骤发生在第 1 步由主体生成密钥对情形下，若在第 1 步由 RA 为主体生成密钥对，则该步骤在第 1 步中完成。

假设用户生成密钥对，则要向注册机构发送公钥和相关注册信息（如主体名，将置于数字证书中）及相关证明材料。用户在特定软件的引导下正确地完成相应输入后通过

Internet 提交至注册机构。证书请求格式已经标准化，称为证书签名请求（Certificate Signing Request, CSR），PKCS#10 证书申请结构如图 9-9 所示。有关 CSR 的详细信息可参看公钥加密标准 PKCS#10。

注意：证明材料未必一定是计算机数据，有时也可以是纸质文档（如护照、营业执照、收入/税收报表复印件等），如图 9-10 所示。

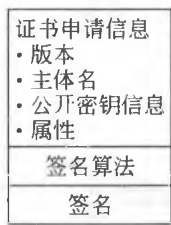


图 9-9 PKCS#10 证书申请结构

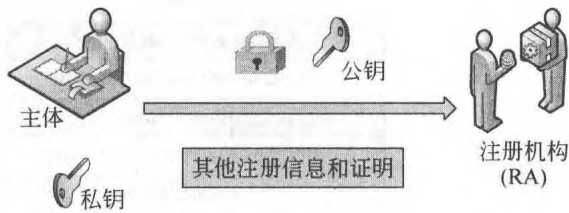


图 9-10 主体将公钥与证明材料发送到注册机构

第 3 步：验证。接收到公钥及相关证明材料后，注册机构须验证用户材料，验证分为以下两个层面。

(1) RA 要验证用户材料，以明确是否接受用户注册。若用户是组织，则 RA 需要检查营业记录、历史文件和信用证明；若用户为个人，则只需简单证明，如验证邮政地址、电子邮件地址、电话号码或护照、驾照等。

(2) 确保请求证书的用户拥有与向 RA 的证书请求中发送的公钥相对应的私钥。这个检查被称为检查私钥的拥有证明（Proof Of Possession, POP）。主要的验证方法有如下几种。

① RA 可要求用户采用私钥对证书签名请求进行数字签名。若 RA 能用该用户公钥验证签名正确性，则可相信该用户拥有与其证书申请中公钥一致的私钥。

② RA 可生成随机数挑战信息，用该用户公钥加密，并将加密后的挑战值发送给用户。若用户能用其私钥解密，则可相信该用户拥有与公钥相匹配的私钥。

③ RA 可将 CA 所生成的数字证书采用用户公钥加密后，发送给该用户。用户需要用与公钥匹配的私钥解密方可取得明文证书——也实现了私钥拥有证明的验证。

第 4 步：证书生成。设上述所有步骤成功，则 RA 将用户的所有细节传递给证书机构。证书机构进行必要的验证，并生成数字证书。证书机构将证书发给用户，并在 CA 维护的证书目录（Certificate Directory）中保留一份证书记录。然后证书机构将证书发送给用户，可附在电子邮件中；也可向用户发送一个电子邮件，通知其证书已生成，让用户从 CA 站点下载。数字证书的格式实际上是不可读的，但应用程序可对数字证书进行分析解释，例如，打开 Internet Explorer 浏览器浏览证书时，可以看到可读格式的证书细节。

9.2.4 数字证书的签名与验证

正如护照需要权威机构的印章与签名一样，数字证书也需要证书机构 CA 采用其私钥签名后方是有效、可信的。接下来，分别就 CA 签名证书及数字证书验证加以介绍。

1. CA 签名证书

此前介绍过 X.509 证书结构，其中最后一个字段是证书机构的数字签名，即每个数字证书不仅包含用户信息（如主体名、公钥等），同时还包含证书机构的数字签名。CA 对数字证书签名过程如图 9-11 所示。

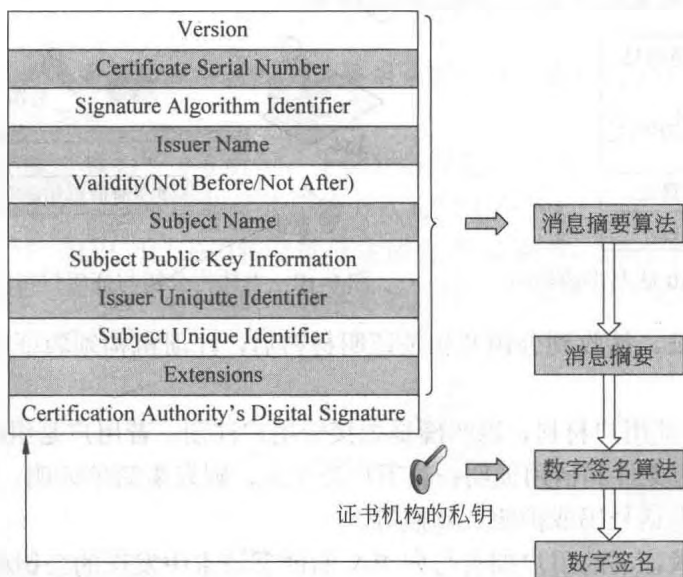


图 9-11 CA 对数字证书签名过程

由图 9-11 可知，在向用户签发数字证书前，CA 首先要对证书的所有字段计算一个消息摘要（使用 MD-5 或 SHA-1 等杂凑算法），而后用 CA 私钥加密消息摘要（如采用 RSA 算法），构成 CA 的数字签名。CA 将计算出的数字签名作为数字证书的最后一个字段插入，类似于护照上的印章与签名。该过程由密码运算程序自动完成。

2. 数字证书验证

数字证书的验证步骤如图 9-12 所示。主要包括如下几步。

(1) 用户将数字证书中除最后一个字段以外的所有字段输入消息摘要算法（杂凑算法）。该算法与 CA 签发证书时使用的杂凑算法相同，CA 会在证书中指定签名算法及杂凑算法，令用户知道相应的算法信息。

(2) 由消息摘要算法计算数字证书中除最后一个字段外其他字段的消息摘要，设该消息摘要为 MD-1。

(3) 用户从证书中取出 CA 的数字签名（证书中最后一个字段）。

(4) 用户用 CA 的公钥对 CA 的数字签名信息进行解密运算。

(5) 解密运算后获得 CA 签名所使用的消息摘要，设为 MD-2。

(6) 用户比较 MD-1 与 MD-2。若两者相符，即 $MD-1=MD-2$ ，则可肯定数字证书已由 CA 用其私钥签名，否则用户不信任该证书，将其拒绝。

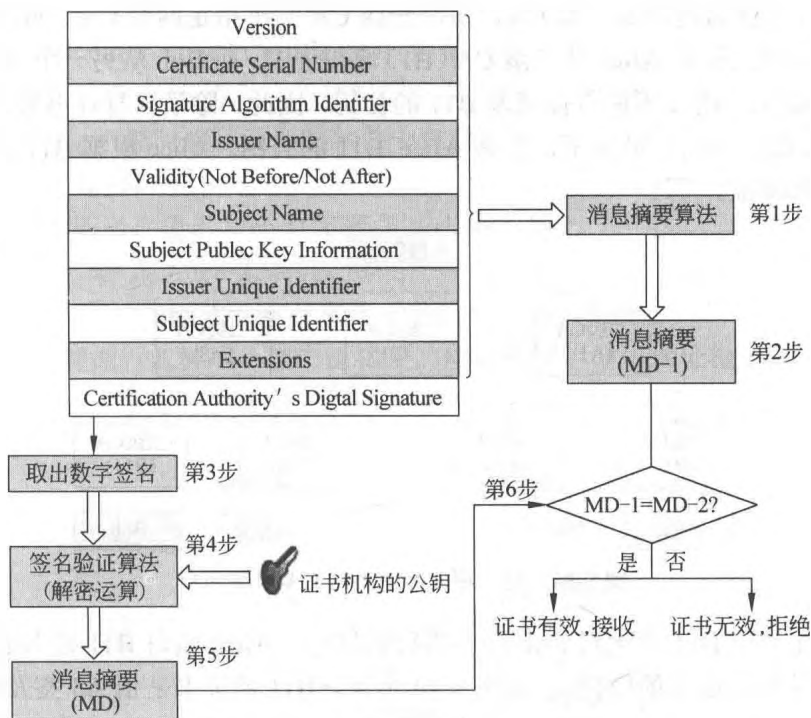


图 9-12 验证 CA 的数字签名

9.2.5 数字证书层次与自签名数字证书

设有两个用户 Alice 与 Bob，二者希望进行安全通信，在 Alice 收到 Bob 的数字证书时，需对该证书进行验证。由前可知，验证证书时需使用颁发该证书的 CA 的公钥，这就涉及如何获取 CA 公钥的问题。

若 Alice 与 Bob 具有相同的证书机构（CA），则 Alice 显然已知签发 Bob 证书的 CA 的公钥。若 Alice 与 Bob 归属于不同的证书机构，则 Alice 需通过如图 9-13 所示的信任链（CA 层次结构）获取签发证书的 CA 公钥。

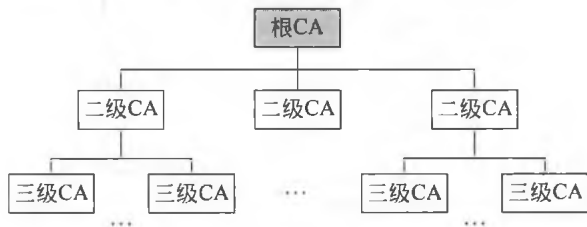


图 9-13 CA 层次结构

由图 9-13 可看出，CA 层次从根 CA 开始，根 CA 下面有一个或多个二级 CA，每个二级 CA 下面有一个或多个三级 CA，等等，类似于组织中的报告层次体系，CEO 或总经理具有最高权威，高级经理向 CEO 或总经理报告，经理向高级经理报告，员工向经理报告……

CA 层次使根 CA 不必管理所有的数字证书，可以将该任务委托给二级机构，每个二

级 CA 又可在其区域内指定三级 CA，每个三级 CA 又可指定四级 CA，依次进行。

如图 9-14 所示，若 Alice 从三级 CA (B1) 取得证书，而 Bob 从另一个三级 CA (B11) 取得证书。显然，Alice 不能直接获取 B11 的公钥，因此，除了自身证书外，Bob 还需向 Alice 发送其 CA (B11) 的证书，告知 Alice B11 的公钥。Alice 根据 B11 的公钥对 Bob 证书进行计算验证。

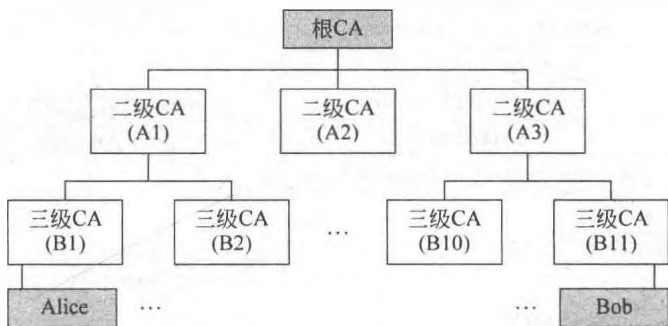


图 9-14 同一根 CA 中不同 CA 所辖用户

显然，在使用 B11 公钥对 Bob 证书进行验证前，Alice 需对 B11 证书的正确性进行验证（确认对 B11 证书的信任）。由图 9-14 可见，B11 的证书是由 A3 签发的，则 Alice 需获得 A3 的公钥以验证 A3 对 B11 证书的签名。同理，为确保 A3 公钥的真实性与正确性，Alice 需获取 A3 的证书，并需获得根 CA 公钥对 A3 证书进行验证。证书层次与根 CA 的验证问题如图 9-15 所示。

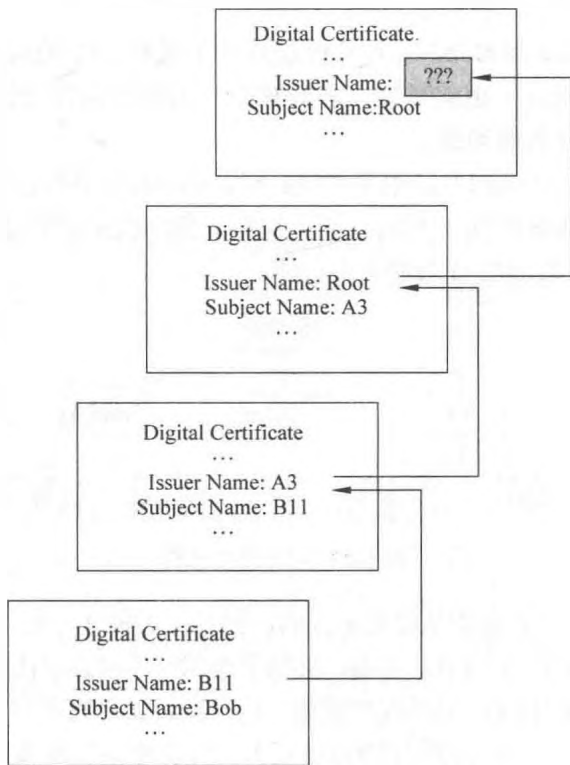


图 9-15 证书层次与根 CA 的验证问题

由图 9-15 可见,根 CA 是验证链的最后一环,根 CA 自动作为可信任 CA,根 CA 证书为自签名证书(Self-signed Certificate),即根 CA 对自己的证书签名,如图 9-16 所示,证书的签发者名和主体名均指向根 CA。存储与验证证书的软件中包含预编程、硬编码的根 CA 证书。

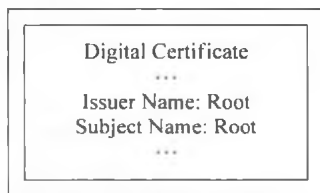


图 9-16 自签名证书

由于根 CA 证书存放于 Web 浏览器和 Web 服务器之类的基础软件中,因此 Alice 无须担心根 CA 证书的认证问题,除非其使用的基础软件本身来自于非信任站点。

Alice 只需采用遵循行业标准、被广泛接受的应用程序,即可保证根 CA 证书的有效性。

图 9-17 显示了验证证书链的过程。

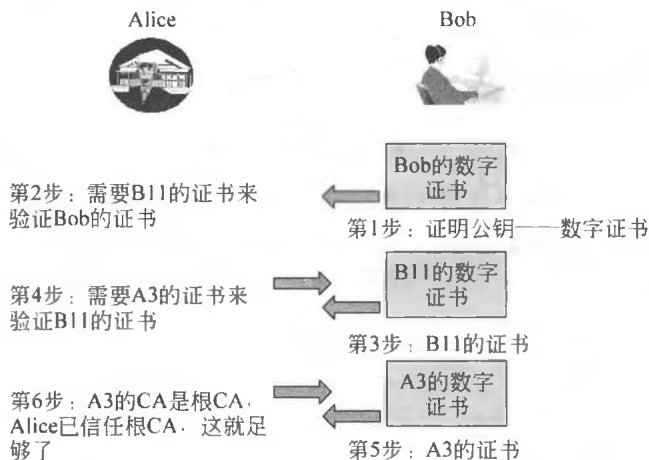


图 9-17 验证证书链的过程

9.2.6 交叉证书

每个国家均拥有不同的根 CA,即使同一国家也可能拥有多个根 CA。例如,美国的根 CA 有 Verisign、Thawte 和美国邮政局。这时,不是各方都能信任同一个根 CA。在 9.2.5 节的示例中,若 Alice 与 Bob 身处不同国家,即根 CA 不同时,也存在着根 CA 的信任问题。

针对以上情形,采用交叉证书(Cross-certification)。由于实际中不可能有一个认证每个用户的统一 CA,因此要用分布式 CA 认证各个国家、政治组织与公司机构的证书。这种方式减少了单个 CA 的服务对象,同时确保 CA 可独立运作。此外,交叉证书使不同 PKI 域的 CA 和最终用户可以互动。交叉证书是对等 CA 签发,建立的是非层次信任路径。

如图 9-18 所示, Alice 与 Bob 的根 CA 不同,但他们可进行交叉认证,即 Alice 的根 CA 从 Bob 的根 CA 那里取得了自身的证书,同样 Bob 的根 CA 从 Alice 的根 CA 处取得了自己的证书。尽管 Alice 的基础软件只信任其自己的根 CA,但因为 Bob 的根 CA 得到了 Alice 的根 CA 的认证,则 Alice 也可信任 Bob 的根 CA。Alice 可采用下列路径验证 Bob 的证书: Bob-Q2-P1-Bob's RCA-Alice's RCA。

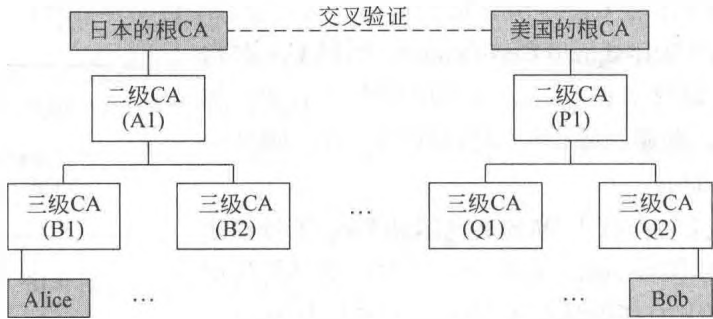


图 9-18 CA 的交叉证书

利用证书层次、自签名证书和交叉证书技术，令所有用户均可验证其他用户的数字证书，以确定信任证书或拒绝证书。

9.2.7 数字证书的撤销

数字证书撤销的常见原因有：①数字证书持有者报告该证书中指定公钥对应的私钥被破解（被盗）；②CA 发现签发数字证书时出错；③证书持有者离职，而证书为其在其在职期间签发的。发生第一种情形需由证书持有者进行证书撤销申请；发生第三种情形时需由组织提出证书撤销申请；发生第二种情形时，CA 启动证书撤销。CA 在接到证书撤销请求后，首先认证证书撤销请求，然后接受请求，启动证书撤销，以防止攻击者滥用证书撤销过程撤销他人证书。

Alice 使用 Bob 的证书与 Bob 安全通信前，需明确以下两点：

- (1) 该证书是否属于 Bob。
- (2) 该证书是否有效，是否被撤销。

Alice 可通过证书链明确第一个问题，而明确第二个问题则需采用证书撤销状态检查机制。CA 提供的证书撤销状态检查机制如图 9-19 所示。



图 9-19 证书撤销状态检查机制

下面对这几种撤销检查机制逐一加以介绍。

1. 脱机证书撤销状态检查

证书撤销列表（Certificate Revocation List, CRL）是脱机证书撤销状态检查的主要方法。最简单的 CRL 是由 CA 定期发布的证书列表，标识该 CA 撤销的所有证书。但该表中不包含过了有效期的失效证书。CRL 中只列出在有效期内因故被撤销的证书。

每个 CA 签发自己的 CRL，CRL 包含相应的 CA 签名，易于验证。CRL 为一个依

时间增长的顺序文件,包括在有效期内因故被撤销的所有证书,是CA签发的所有CRL的子集。每个CRL项目列出证书序号、撤销日期和时间、撤销原因。CRL顶层还包括CRL发布的日期、时间和下一个CRL发布时间。图9-20给出了CRL文件的逻辑视图。

Alice对Bob数字证书的安全性检查操作如下。

- (1) 证书有效期检查: 比较当前日期与证书有效期, 确保证书在有效期内。
- (2) 签名检查: 检查Bob的证书能否用其CA的签名验证。

CA: XYZ Certificate Revocation List(CRL) This CRL: 1 Jan 2002, 10: 00 am Next CRL: 12 Jan 2002, 10: 00 am		
Serial Number	Date	Reason
1234567	30-Dec-01	Private key compromised
2819281	30-Dec-01	Changed job
...	...	...

图9-20 CRL文件的逻辑视图

(3) 证书撤销状态检查: 根据Bob的CA签发的最新CRL检查Bob的证书是否在证书撤销列表中。

完成以上检查后, Alice方能信任Bob的数字证书, 相应过程如图9-21所示。

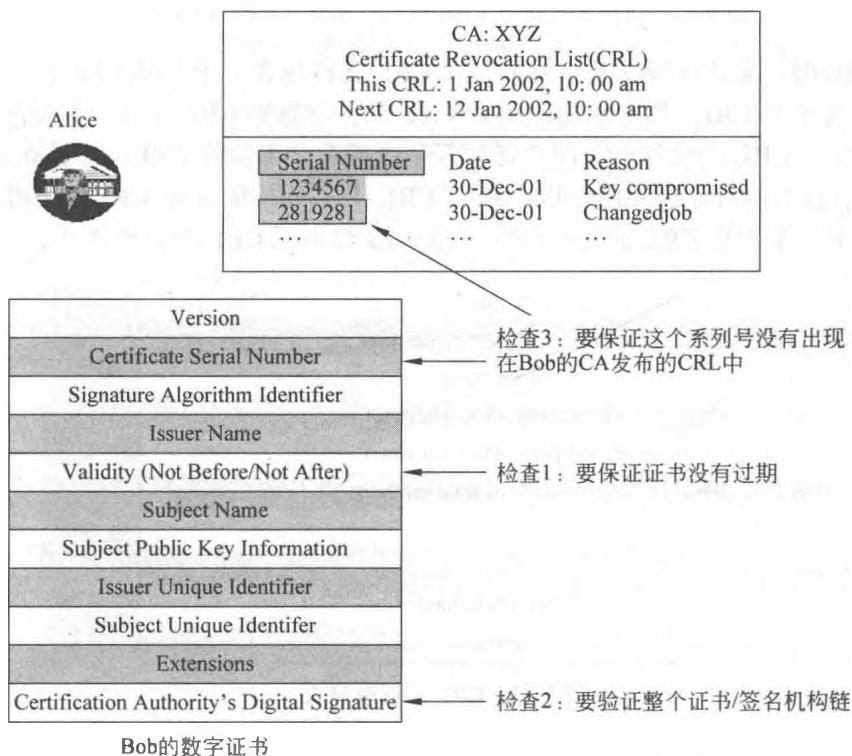


图9-21 检验证书及CRL在检验过程中作用

随着时间的推移，CRL 可能会变得很大。一般假设，每年撤销的未到期证书达 10% 左右，若 CA 有 100 000 个用户，则两年时间可能在 CRL 中有 20 000 个项目，数目是相当庞大的。在这种情形下，通过网络接收 CRL 文件将是一个很大的瓶颈。为解决该问题，引出了差异 CRL（Delta CRL）的概念。

最初，CA 可以向使用 CRL 服务的用户发一个一次性的完全更新 CRL，称为基础 CRL（Base CRL）。下次更新时，CA 不必发送整个 CRL，而只需发送上次更新以来改变的 CRL。这个机制令 CRL 文件的长度缩小，从而加快传输速度。基础 CRL 的改变称为差异 CRL，差异 CRL 也是一个需要 CA 签名的文件。图 9-22 给出了每次签发完整 CRL 与只签发差异 CRL 的区别。

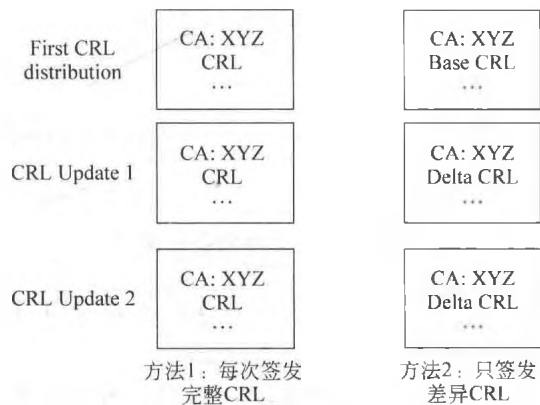


图 9-22 每次签发完整 CRL 与只签发差异 CRL 的区别

使用 CRL 时，需注意以下几点：①差异 CRL 文件包含一个差异 CRL 标识符，告知用户该 CRL 为差异 CRL，用户需将该差异 CRL 文件与基础 CRL 文件一起使用，得到完整 CRL；②每个 CRL 均有序号，用户可检查是否拥有全部差异 CRL；③基础 CRL 可能有一个差异信息标识符，告知用户这个基础 CRL 具有相应的差异 CRL，还可提供差异 CRL 地址和下一个差异 CRL 的发布时间。图 9-23 给出了 CRL 的标准格式。

Version	头字段
Signature Algorithm Identifier	
Issuer Name	
This Update (Date and Time)	
Next Update (Date and Time)	
User CERTIFICATE Serial Number Revocation Data CRL Entry Extensions	重复项
...	
...	
CRL Extensions	尾字段
Signature	

图 9-23 CRL 的标准格式

如图 9-23 所示，CRL 格式中有几个头字段、几个重复项目和几个尾字段。显然，序号、撤销日期、CRL 项目扩展之类的字段要对 CRL 中的每个撤销证书重复。而其他字段构成头字段、尾字段两部分。下面介绍这些字段，如表 9-3 所示。

表 9-3 CRL 的不同字段

字 段	描 述
版本 (Version)	表示 CRL 版本
签名算法标识符 (Signature Algorithm Identifier)	CA 签名 CRL 所用的算法 (如 SHA-1 与 RSA)，表示 CA 先用 SHA-1 算法计算 CRL 的消息摘要，然后用 RSA 算法签名
签发者名 (Issuer Name)	标识 CA 的可区分名 (DN)
本次更新日期与时间 (This Update Date and Time)	签发这个 CRL 的日期与时间值
下次更新日期与时间 (Next Update Date and Time)	签发下一个 CRL 的日期与时间值
用户证书序号 (User Certificate Serial Number)	撤销证书的证书号，该字段对每个撤销证书重复
撤销日期 (Revocation Date)	撤销证书的日期和时间，该字段对每个吊销证书重复
CRL 项目扩展 (CRL Entry Extension)	见表 9-4，每个 CRL 项目有一个扩展
CRL 扩展 (CRL Extension)	见表 9-5，每个 CRL 有一个扩展
签名 (Signature)	包含 CA 签名

这里，需明确区别 CRL 项目扩展与 CRL 扩展，CRL 项目扩展对每个撤销证书重复，而整个 CRL 只有一个 CRL 扩展，如表 9-4 和表 9-5 所示。

表 9-4 CRL 项目扩展

字 段	描 述
原因代码 (Reason Code)	指定证书撤销原因，可能是 Unspecified (未指定)，Key Compromise (密钥损坏)，CA Compromise (CA 被破坏)，Superseded (重叠)，Certificate Hold (证书暂扣)
扣证指示代码 (Hold Instruction Code)	证书可以暂扣，即在指定时间内失效 (可能因为用户休假，需保证期间不被滥用)，该字段可指定扣证原因
证书签发者 (Certificate Issuers)	标识证书签发者和间接 CRL。间接 CRL 是第三方提供的，而非证书签发者提供。第三方可汇总多个 CA 的 CRL，发一个合并的间接 CRL，使 CRL 信息请求更加方便
撤销日期 (Invalidity Date)	发生私钥泄漏或数字证书失效的日期和时间

表 9-5 CRL 扩展

字 段	描 述
机构密钥标识符 (Authority Key Identifier)	区别一个 CA 使用的多个 CRL 签名密钥
签发者别名 (Issuer Alternative Name)	将签发者与一个或多个别名相联系
CRL 号 (CRL Number)	序号 (随每个 CRL 递增)，帮助用户明确是否拥有此前所有的 CRL
差异 CRL 标识符 (Delta CRL Indicator)	表示 CRL 为差异 CRL
签发发布点 (Issuing Distribution Point)	表示 CRL 发布点或 CRL 分区。CRL 发布点可在 CRL 很大时使用——不用发布一个庞大的 CRL，而是分解为多个 CRL 发布。CRL 请求者请求和处理这些小的 CRL。CRL 发布点提供了小 CRL 的地址指针 (即 DNS 名、IP 地址或文件名)

和最终用户一样，CA 本身也用证书标识。在某些情形下，CA 证书也需撤销，类似于 CRL 提供最终用户证书的撤销信息表，机构撤销列表（ARL）提供了 CA 证书的撤销信息表。

2. 联机证书撤销状态检查

由于 CRL 可能过期，同时 CRL 存在长度问题，基于 CRL 的脱机证书撤销状态检查不是检查证书撤销的最好方式。因此，出现了两个联机检查证书状态协议：联机证书状态协议和简单证书检验协议。

联机证书状态协议（Online Certificate Status Protocol，OCSP）可以检查特定时刻某个数字证书是否有效，是联机检查方式。联机证书状态协议令证书检验者可以实时检查证书状态，从而提供了更简单、快捷、有效的数字证书验证机制。与 CRL 不同，该方式无须下载证书列表。下面介绍联机证书状态协议的工作步骤。

（1）CA 提供一个服务器，称为 OCSP 响应器（OCSP Responder），该服务器包含最新证书撤销信息。请求者（客户机）发送联机证书状态查询请求（OCSP Request），检查该证书是否撤销。OCSP 最常用的基础协议是 HTTP，但也可以使用其他应用层协议（如 SMTP），如图 9-24 所示。实际上，OSCP 请求还包括 OSCP 版本、请求服务和一个或几个证书标识符（其中包含签发者的消息摘要、签发者公钥的消息摘要和证书序号）。为简单起见，暂忽略这些细节。

（2）OCSP 响应器查询服务器的 X.500 目录（CA 不断向其提供最新证书撤销信息），以明确特定证书是否有效，如图 9-25 所示。



图 9-24 OCSP 请求

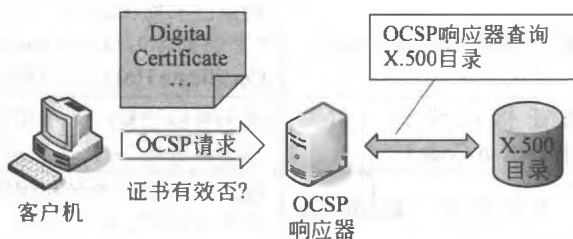


图 9-25 OCSP 证书撤销状态检查

（3）根据 X.500 目录查找的状态检查结构，OCSP 响应器向客户机发送数字签名的 OCSP 响应（OCSP Response），原请求中的每个证书有一个 OCSP 响应。OCSP 响应可以取 3 个值，即 Good、Revoked 或 Unknown。OCSP 响应还可以包含撤销日期、时间和原因。客户机要确定相应的操作。一般而言，建议只在 OCSP 响应状态为 Good 时才认为证书有效，OCSP 响应如 9-26 所示。

需要注意的是，OCSP 缺少对与当前证书相关的证书链有效性的检查。例如，假设 Alice 要用 OCSP 验证 Bob 的证书，则 OCSP 只是告诉 Alice，Bob 的证书是否有效，而不检验签发 Bob 证书的 CA 的证书或证书链中更高层的证书。这些逻辑（验证证书链有效性）要放在使用 OCSP 的客户机应用程序中。另外，客户机应用程序还要检查证书有效期、密钥使用合法性和其他限制。

简单证书检验协议（Simple Certificate Validation Protocol，SCVP）目前还是草案，

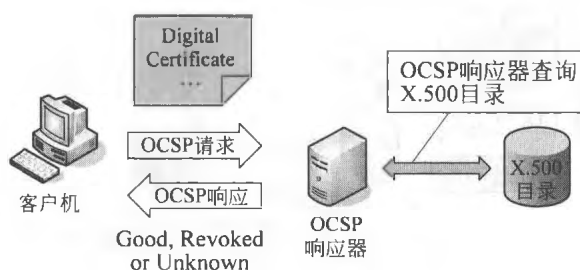


图 9-26 OCSP 响应

是联机证书状态报告协议，用于克服 OCSP 的缺点。SCVP 与 OCSP 在概念上非常相似，这里仅指出两者的差别，如表 9-6 所示。

表 9-6 OCSP 与 SCVP 的差别

特 点	OCSP	SCVP
客户端请求	客户机只向服务器发送证书序号	客户机向服务器发送整个证书，因此服务器可以进行更多的检查
信任链	只检查指定证书	客户机可以提供中间证书集合，让服务器检查
检查	只检查证书是否撤销	客户机可以请求其他检查（如检查整个信任链）、考虑的撤销信息类型（如服务器是否用 CRL 或 OCSP 进行撤销检查），等等
返回信息	只返回证书状态	客户机可以指定感兴趣的其他信息（如服务器要返回撤销状态证明或返回信任验证所用的证书链，等等）
其他特性	无	客户机可以请求检查证书的过去事件。例如，假设 Bob 向 Alice 发了证书和签名文档，则 Alice 可以用 SCVP 检查 Bob 的证书在签名时是否有效（而非验证签名时）

9.2.8 漫游证书

数字证书应用的普及产生了证书的便携性需求。此前提供证书及其对应私钥移动性的实际解决方案主要分为两种：①智能卡技术，在该技术中，公钥/私钥对存放在卡上，但这种方法存在缺陷，如易丢失和损坏，并且依赖读卡器（虽然带 USB 接口的智能钥匙不依赖于读卡器，但成本太高）；②将证书和私钥复制到一张软盘上备用，但软盘不仅容易丢失和损坏，而且安全性较差。

一个新的解决方案就是使用漫游证书。它通过第三方软件提供，在任何系统中，只需正确配置，该软件（或插件）就可以允许用户访问自己的公钥/私钥对。其基本原理非常简单，如下所述。

（1）将用户的证书和私钥放在一个安全的中央服务器（称为证件服务器）数据库中，如图 9-27 所示。

（2）当用户登录到一个本地系统时，使用用户名和口令通过 Internet 向证件服务器认证自己，如图 9-28 所示。

（3）证件服务器用证件数据库验证用户名和口令，如果认证成功，则证件服务器将数字证书与私钥文件发送给用户，如图 9-29 所示。

（4）当用户完成工作并从本地系统注销后，该软件自动删除存放在本地系统中的用

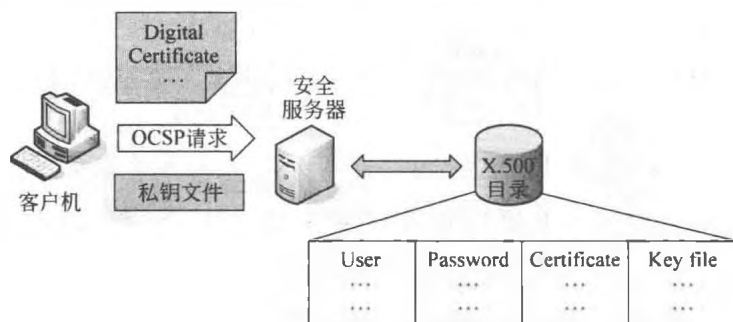


图 9-27 漫游证书用户注册

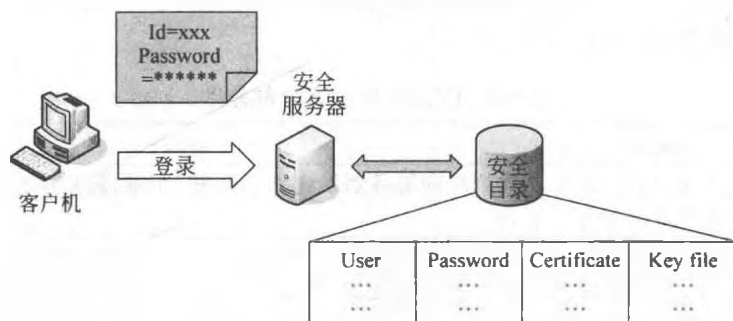


图 9-28 漫游证书用户登录

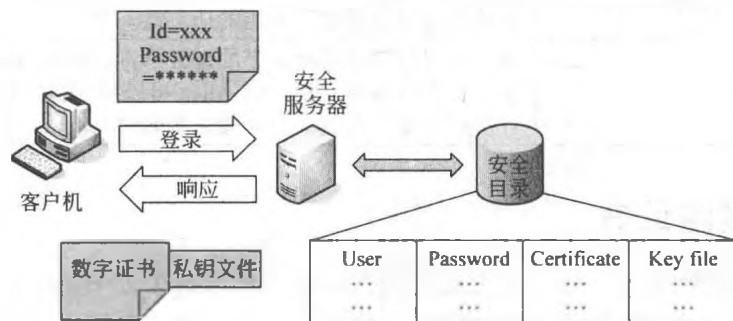


图 9-29 漫游证书用户接收数字证书与私钥文件

户证书和私钥。

这种解决方案的优点是可以明显提高易用性、降低证书的使用成本，但它与已有的一些标准不一致，因而在应用中受到了一定限制。在小额支付等低安全要求的环境中，该解决方案是一种较合适的方法。

9.2.9 属性证书

另一个与数字证书相关的新标准是属性证书（Attribute Certificate, AC）标准。属性证书的结构与数字证书相似，但作用不同。属性证书不包含用户的公钥，而是在实体及其一组属性之间建立联系（如成员关系、角色、安全清单和其他授权细节）。和数字证书一样，属性证书也通过签名检验内容的改变。

属性证书可以在授权服务中控制对网络、数据库等的访问和对特定物理环境的访问。

9.3

PKI 体系结构——PKIX 模型

X.509 标准定义了数字证书结构、格式与字段，还指定了发布公钥的过程。为了扩展该标准，令其更通用，Internet 工作任务组（IETF）建立了公钥基础设施 X.509（Public Key Infrastructure X.509, PKIX）工作组，扩展 X.509 标准的基本思想，指定 Internet 中如何部署数字证书。此外，还为不同领域的应用程序定义了其他 PKI 模型。本节仅对 PKIX 模型进行简要介绍。

9.3.1 PKIX 服务

PKIX 提供的公钥基础设施服务包括以下几个方面。

- (1) 注册。该过程是最终实体（主体）向 CA 介绍自己的过程，通常通过注册机构进行。
- (2) 初始化。处理基础问题，如最终实体如何保证对方是正确的 CA。
- (3) 认证。CA 对最终实体生成数字证书并将其交给最终实体，维护复制记录，并在必要时将其复制到公共目录中。
- (4) 密钥对恢复。一定时间内可能要恢复加密运算所用的密钥，以便旧文档解密。密钥存档和恢复服务可以由 CA 提供，也可由独立的密钥恢复系统提供。
- (5) 密钥生成。PKIX 指定最终实体应能生成公钥/私钥对，或由 CA/RA 为最终实体生成（并将其安全地发布给最终实体）。
- (6) 密钥更新。可以从旧密钥对向新密钥对顺利过渡，进行数字证书自动刷新。也可提供手工数字证书更新请求与响应。
- (7) 交叉证书。建立信任模型，使不同 CA 认证的最终实体可以相互验证。
- (8) 撤销。PKIX 可以支持两种证书状态检查模型——联机（使用 OCSP）或脱机（CRL）。

9.3.2 PKIX 体系结构

PKIX 建立了综合性文档，介绍其体系结构模型的 5 个域，包括以下几方面。

- (1) X.509 v3 证书与 v2 证书撤销列表配置文件。X.509 标准可以用各种选项描述数字证书扩展。PKIX 把适合 Internet 用户使用的所有选项组织起来，称为 Internet 用户的配置文件。该配置文件（参看 RFC 2459）指定必须/可以/不能支持的属性，并提供了每个扩展类所用值的取值范围。例如，基本 X.509 标准没有指定证书暂扣时的指示代码——PKIX 定义了相应代码。
- (2) 操作协议。定义基础协议，向 PKI 用户发布证书、CRL 和其他管理与状态信息的传输机制。由于每个要求都有不同的服务方式，因此定义了 HTTP、LDAP、FTP、X.500 等的用法。
- (3) 管理协议。这些协议支持不同 PKI 实体交换信息（如传递注册请求、撤销状态或交叉证书请求与响应）。管理协议指定实体间浮动的信息结构，还指定处理这些信息所需的细节。管理协议的一个示例是请求证书的证书管理协议（Certificate Management Protocol, CMP）。

（4）策略大纲。PKIX 在 RFC 2527 中定义了证书策略（Certificate Policies, CP）和证书实务声明（Certificate Practice Statements, CPS）的大纲，其中定义了生成证书策略之类的文档，确定对于特定应用领域选择证书类型时要考虑的重点。

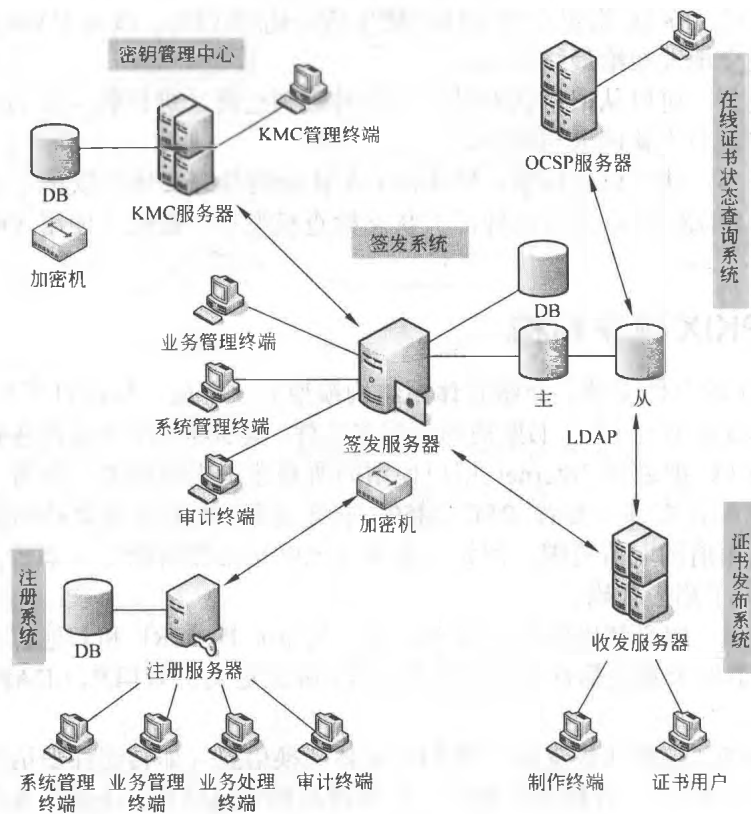
（5）时间标注与数据证书服务。时间标注服务是由所谓时间标注机构的信任第三方提供的，这个服务的目的是签名消息，保证其在特定日期和时间之间存在，帮助处理不可抵赖争端。数据证书服务（DCS）是信任第三方服务，验证所收到数据的正确性，类似于日常生活中的公证方。

9.4 PKI 实例

整个系统由下列子系统构成：

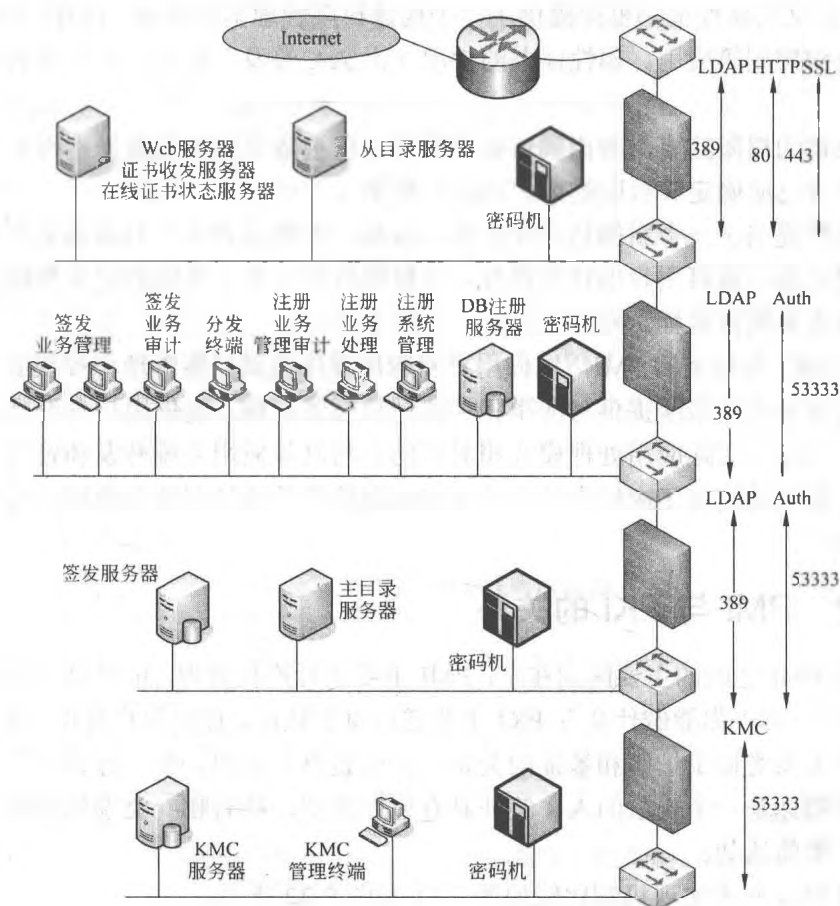
- 签发系统（Authority）。
- 密钥管理中心系统（KMC）。
- 申请注册系统（RA）。
- 证书发布系统（DA）。
- 在线证书状态查询系统（OCSP）。

由各子系统组成的 PKI/CA 认证系统的结构如图 9-30 所示。



(a) PKI 系统的拓扑结构

图 9-30 PKI/CA 认证系统的结构



(b) 一个PKI系统实例

图 9-30 (续)

9.5 授权管理设施——PMI

9.5.1 PMI 的定义

ITU&IETF 编写的相关文档说明了如何使用属性证书实现 PMI。PMI 即权限管理基础设施或授权管理基础设施，是属性证书、属性权威、属性证书库等部件的集合体，用来实现权限和证书的产生、管理、存储、分发和撤销等功能。

AA (Attribute Authority, AA) 即属性权威，是用来生成并签发属性证书 (AC) 的机构。它负责管理属性证书的整个生命周期。

AC (Attribute Certificate, AC) 即属性证书，对于一个实体的权限绑定是由一个被数字签名的数据结构来提供的，这种数据结构称为属性证书，由属性权威签发并管理，它包括一个展开机制和一系列特别的证书扩展机制。下面称公钥证书为 PKC (Public Key Certificate)。

X.509 定义的属性证书框架提供了一个构建权限管理基础设施（PMI）的基础，这些结构支持访问控制等应用。属性证书的使用（由 AA 签发）提供一个灵活的权限管理基础设施。

一个实体的权限约束，应由属性证书权威（已被数字签名的数据结构）或由公钥证书权威（包含已明确定义权限约束扩展的）提供。

PMI 实际提出了一个新的信息保护基础设施，能够与 PKI 和目录服务紧密地集成，并系统地建立起对认可用户的特定授权，对权限管理进行了系统的定义和描述，完整地提供了授权服务所需过程。

建立在 PKI 基础上的 PMI，以向用户和应用程序提供权限管理和授权服务为目标，主要负责向业务应用系统提供与应用相关的授权服务管理，提供用户身份到应用授权的映射功能，实现与实际应用处理模式相对应的、与具体应用系统开发和管理无关的访问控制机制，极大地简化了应用中访问控制和权限管理系统的开发与维护，并减少了管理成本和复杂性。

9.5.2 PMI 与 PKI 的关系

PKI 和 PMI 之间的主要区别在于：PMI 主要进行授权管理，证明这个用户有什么权限，能干什么，即“你能做什么”；PKI 主要进行身份认证，证明用户身份，即“你是谁”。它们之间的关系类似于护照和签证的关系。护照是身份证明，唯一标识个人，只有持有护照才能证明你是一个合法的人。签证具有属性类别，持有哪一类别的签证才能在该国家进行哪一类的活动。

PKI 和 PMI 两者实现机制比较如图 9-31 和图 9-32 所示。

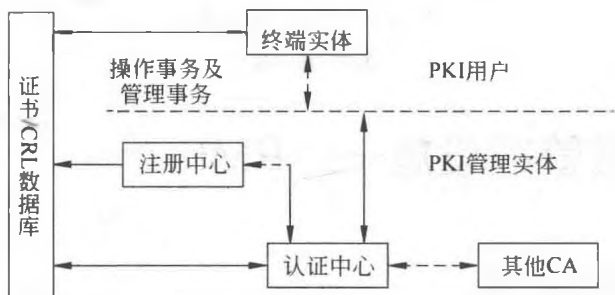


图 9-31 PKI 组织结构

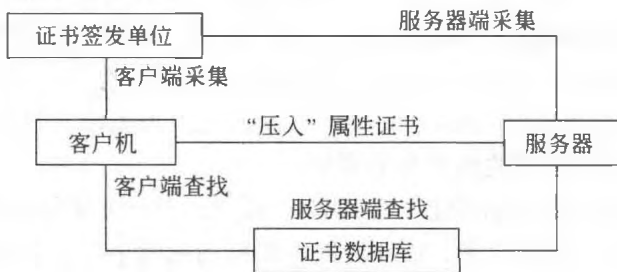


图 9-32 PMI 组织结构

由于在 X.509 中定义, 一个实体的权限约束由属性证书权威 (已被数字签名的数据结构) 或由公钥证书权威 (包含已明确定义权限约束扩展的) 提供。授权信息可以放在身份证书扩展项 (Subject Directory Attribute) 或属性证书中, 但是将授权信息放在身份证书中是很不方便的。首先, 授权信息和公钥实体的生存期往往不同, 授权信息放在身份证书扩展项中导致的结果是缩短了身份证书的生存期, 而身份证书的申请审核签发的代价是较高的; 其次, 对于授权信息来说, 身份证书的签发者通常不具有权威性, 这就导致身份证书的签发者必须使用额外步骤从权威源获得信息。另外, 由于授权发布要比身份发布频繁得多, 对于同一个实体可由不同的属性权威来颁发一属性证书, 赋予不同的权限, 因此, 一般使用属性证书来容纳授权信息, PMI 可由 PKI 建造出来且可独立地执行管理操作。但是两者之间还存在着联系, 即 PKI 可用于认证属性证书中的实体和所有者身份, 并鉴别属性证书签发权威 AA 的身份。

PMI 和 PKI 有很多相似的概念, 如属性证书与公钥证书、属性权威与认证权威等。表 9-7 是对它们的比较。

表 9-7 PMI 和 PKI 实体比较

内 容	PKI 实体	PMI 实体
证书	PKC 公钥证书	AC 属性证书
证书颁发者	证书机构	属性机构
证书接收者	证书主体	证书持有者
证书的绑定	主体的名字绑定到公钥上	证书持有者绑定到一个或多个特权属性上
证书撤销	证书撤销列表 (CRL)	属性证书撤销列表 (ACRL)
信任的根	根 CA 或信任锚	权威源 SOA
子机构	子 CA	AA
验证者	可信方	特权验证者

公钥证书将用户名称及其公钥进行绑定, 而属性证书则将用户名称与一个或更多的权威属性进行绑定。在这个方面, 公钥证书可被看做是特殊的属性证书。

数字签名公钥证书的实体被称为 CA, 签名属性证书的实体被称为 AA。

PKI 信任源有时被称为根 CA, 而 PMI 信任源被称为起始授权机构或权威源 (SOA)。

CA 可以有它们信任的次级 CA, 次级 CA 可以代理鉴别和认证, SOA 可以将它们的权利授给次级 AA。如果用户需要废除他的签字密钥, 则 CA 将签发证书撤销列表。与之类似, 如果用户需要废除授权允许 (Athorization Permission), AA 将签发一个属性证书撤销列表 (ACRL)。

9.5.3 实现 PMI 的机制

实现 PMI 有多种机制, 大致可分为 3 类。

1. 基于 Kerberos 的机制

Kerberos 是基于对称密码技术的, 它具有对称算法的一些优秀性能, 如便于软硬件实现、比非对称密码算法速度更快。但是, 它存在不便于密钥管理和单点失败的问题。

这种机制最适合用于大量的实时事务处理环境中的授权管理。

2. 基于策略服务器概念的机制

这种机制中有一个中心的服务器，用来创建、维护和验证身份，组合角色。它实行的是高度集中的控制方案，便于实行单点管理，但却容易形成通信的“瓶颈”。这种机制最适合用于地理位置相对集中的实体环境，具有很强的中心管理控制功能。

3. 基于属性证书的机制

类似于公钥证书的概念，但不包括公钥。这种机制是完全的分布式解决方案，具有失败拒绝的优点，但由于基于公钥的操作（因为 AC 使用数字签名进行认证和完整性校验，包含的属性可以用加密技术确保机密性，这些都用了公钥技术），性能不高。这种机制适用于支持不可否认服务的授权管理。

基于 AC 的机制可以直接使用 PKI.X.509—2000 利用属性证书定义 PMI，以及如何利用 PKI-CA 进行对用户访问的授权管理。从 PMI 框架定义的基础看，可以发现 PMI 与 PKI 必然具有很多相似之处。

总之，PKI 处理的是公开密钥证书，包括创建、管理、存储、分发和撤销公开密钥证书的一整套硬件、软件、人员、策略和过程。而 PMI 处理的是 AC 的管理，与 PKI 类似，它包括了创建、管理、存储、分发和撤销 AC 的技术和过程。

9.5.4 PMI 模型

由于绝大多数的访问控制应用都能抽象成一般的权限管理模型，包括 3 个实体：对象、权限声称者（Privilege Asserter）和权限验证者（Privilege Verifier）。因此，PMI 的基本模型包括 3 个实体：目标、权限持有者和权限验证者。PMI 基本模型如图 9-33 所示。

目标可以是被保护的资源，例如，在一个访问控制应用中，受保护的资源就是目标；权限持有者就是持有特定特权并为某个使用决定特权的实体；权限验证者对访问动作进行验证和决策，是制定决策的实体，是决定某次使用的特权是否充分的实体。

权限验证者根据 4 个条件决定访问“通过/失败”：①权限声明者的权限；②适当的权限策略；③当前环境变量（如果有）；④对象方法的敏感度（如果有）。

其中，权限策略说明了对于给定敏感度的对象方法或权限的用法和内容，用户持有的权限需要满足什么条件和达到什么要求。权限策略准确定义了什么时候权限验证者应该确定一套已存在的权限是“充分的”，以便许可（对要求的对象、资源、应用等）权限持有者访问。为了保证系统的安全性，权限策略需要完整性和可靠性保护，防止他人通过修改策略而攻击系统。

控制模型如图 9-34 所示，它说明了如何控制对敏感目标程序的接入。该模型有 5 个基本组件：权限持有者、权限验证者、目标程序、权限策略和环境变量。其中，权限验证者与 PMI 基本模型中的组件解释相同；权限持有者可以由公钥证书或档案资料所定义的实体；目标程序含有敏感信息。



图 9-33 PMI 基本模型



图 9-34 控制模型

该模型描述的方法，使得特权验证者能够通过特权持有者与特权策略保持一致来达到对环境变量的接入控制。

特权和敏感性可以有多个参数值。

委托模型（如图 9-35 所示），在有些环境下可能会需要委托特权，但是，这种框架是可选项，并不是所有的环境都必需的。这种模型有 4 个组件：权限验证者、终端实体、SOA 和普通 AA。在使用委托的环境下，SOA 成为证书的最初颁发者，SOA 指定一些特权持有者作为 AA 并向其分配特权由 AA 进一步向其他实体授权特权。

角色模型（如图 9-36 所示）为角色提供了一种间接的向个体分配特权的方式。个体通过证书中的角色属性分配到一个或多个角色。AA 可以定义任意数目的角色；角色本身和角色成员也可以由不同的 AA 分别定义和管理；角色的关系类似于其他特权，是可以委托的；可以向角色和角色的关系分配任何合适的生命周期。

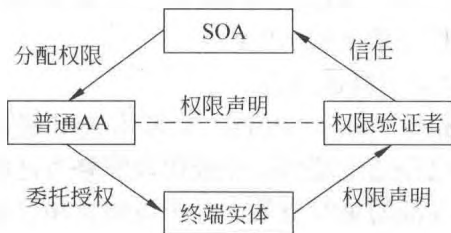


图 9-35 委托模型



图 9-36 角色模型

9.5.5 基于 PMI 建立安全应用

PKI /PMI 和应用的逻辑结构如图 9-37 所示。

图 9-37 所示各部分说明如下。

（1）访问者、目标：访问者是一个实体（该实体可能是人，也可能是其他计算机实体），它试图访问系统内的其他实体（目标）。

（2）策略：授权策略展示了一个机构在信息安全和授权方面的顶层控制、授权遵循的原则和具体的授权信息。在一个机构的 PMI 应用中，策略应当包括一个机构如何将它的人员和数据进行分类组织，这种组织方式必须考虑到具体应用的实际运行环境，如数据的敏感性、人员权限的明确划分及必须和相应人员层次相匹配的管理层次等因素。所以，策略的制定是需要根据具体的应用量身定做的。

策略包含着应用系统中的所有用户和资源信息及用户和信息的组织管理方式、用户和资源之间的权限关系、保证安全的管理授权约束、保证系统安全的其他约束。在 PMI 中主要使用基于角色的访问控制（Role-Based Access Control, RBAC）。

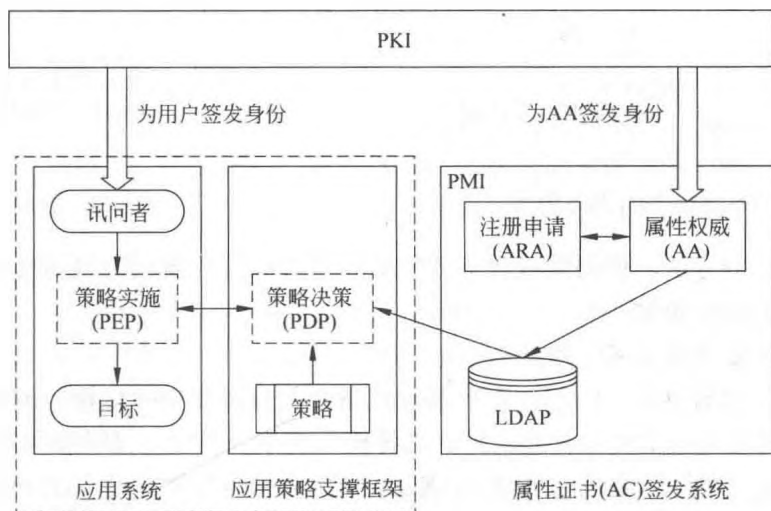


图 9-37 PKI/PMI 和应用的逻辑结构

(3) **AC**: 属性证书 (AC) 是 PMI 的基本概念, 它是权威签名的数据结构, 将权限和实体信息绑定在一起。属性证书中包含了用户在某个具体的应用系统中的角色信息, 而该角色具有什么样的权限是在策略中指定的。

(4) **AA**: 属性证书的签发者被称为属性权威 AA, 属性权威 AA 的根称为 SOA。

(5) **ARA**: 属性证书的注册申请机构称为属性注册权威 ARA。

(6) **LDAP**: 用来存储签发的属性证书和属性证书撤销列表。

(7) **策略实施**: 策略实施点 (Policy Enforcement Points, PEPs) 也称为 PMI 激活的应用, 对每一个具体的应用可能是不同的, 是指已经通过接口插件或代理所修改过的应用或服务, 这种应用或服务被用来实施一个应用内部的策略决策, 介于访问者和目标之间, 当访问者申请访问时, 策略实施点向授权策略服务器申请授权, 并根据授权决策的结果实施决策, 即对目标执行访问或拒绝访问。在具体的应用中, 策略实施点可能是应用程序内部中进行访问控制的一段代码, 也可能是安全的应用服务器 (如在 Web 服务器上增加一个访问控制插件), 或者是进行访问控制的安全应用网关。

(8) **策略决策**: 策略决策点 (Policy Decision Point, PDP) 也称为授权策略服务器, 它接收和评价授权请求, 根据具体策略做出不同的决策。它一般不随具体的应用变化, 是一个通用的处理判断逻辑。当接收到一个授权请求时, 根据授权策略、访问者的安全属性及当前条件进行决策, 并将决策结果返回给应用。对不同应用的支持是通过解析不同的定制策略来完成的。

在实施的过程中, 只需定制策略实施部分并定义相关策略。

习 题

一、选择题

1. 数字证书将用户与其_____相联系。

- A. 私钥 B. 公钥 C. 护照 D. 驾照
2. 用户的_____不能出现在数字证书中。
A. 公钥 B. 私钥 C. 组织名 D. 人名
3. _____可以签发数字证书。
A. CA B. 政府 C. 小店主 D. 银行
4. _____标准定义数字证书结构。
A. X.500 B. TCP/IP C. ASN.1 D. X.509
5. RA_____签发数字证书。
A. 可以 B. 不必 C. 必须 D. 不能
6. CA 使用_____签名数字证书。
A. 用户的公钥 B. 用户的私钥 C. 自己的公钥 D. 自己的私钥
7. 要解决信任问题, 需使用_____。
A. 公钥 B. 自签名证书 C. 数字证书 D. 数字签名
8. CRL 是_____的。
A. 联机 B. 联机和脱机 C. 脱机 D. 未定义
9. OCSP 是_____的。
A. 联机 B. 联机和脱机 C. 脱机 D. 未定义
10. 最高权威的 CA 称为_____。
A. RCA B. RA C. SOA D. ARA

二、思考题

1. 数字证书的典型内容是什么?
2. CA 与 RA 的作用是什么?
3. 简述交叉证书的作用。
4. 简述撤销证书的原因。
5. 列出创建数字证书的 4 个关键步骤。
6. CA 分层后面的思想是什么?
7. 描述保护数字证书的机制。
8. 为什么需要自签名证书?
9. CRL、OCSP、SCVP 的主要区别是什么?
10. 请看这样一种情况:

攻击者 A 创建了一个证书, 放置一个真实的组织名 (假设为银行 B) 及攻击者自己的公钥。你在不知道是攻击者在发送的情形下, 得到了该证书, 误认为该证书来自银行 B。请问如何防止该问题的产生?